

IT AUDIT CHECKLIST

A Risk-Based, Framework-Aligned Audit Checklist
for Internal & External IT Auditors

17
Audit Domains

150+
Checklist Items

4
Frameworks

5
Risk Levels

ISO/IEC 27001:2022 | ITIL 5 | COBIT 2019 | NIST SP 800-53 | ISO 19011:2018

IT Governance	Risk & Compliance	Info Security	Asset Mgt	IAM	IT Operations	Change Mgt	Infrastructure	AppSec
Data Protection	Logging & SIEM	BC/DR	Physical Security	Vendor Mgt	IT Finance	Audit Trails	Emerging Tech	

TABLE OF CONTENTS

1.	IT Governance & Management Oversight	COBIT EDM / APO
2.	IT Risk Management & Compliance	ISO 27001 Cl.6 / COBIT APO12
3.	Information Security Management	ISO/IEC 27001:2022 Annex A
4.	IT Asset Management	ISO 27001 A.5.9 / COBIT BAI09
5.	Identity & Access Management (IAM)	ISO 27001 A.5.15-18 / NIST AC
6.	IT Operations & Service Management	ITIL 5 / COBIT DSS01
7.	Change Management & Release Management	ITIL Change Control / COBIT BAI06
8.	IT Infrastructure & Network Security	ISO 27001 A.8 / NIST SC
9.	Application Controls & Systems Development	NIST SA / COBIT BAI03
10.	Data Management & Protection	ISO 27001 A.5.12 / GDPR
11.	Logging, Monitoring & Incident Response	ISO 27001 A.8.15 / NIST AU/IR
12.	Business Continuity & Disaster Recovery	ISO 22301 / NIST CP
13.	Physical & Environmental Security	ISO 27001 A.7 / NIST PE
14.	Vendor & Third-Party Management	ISO 27001 A.5.19 / COBIT APO10
15.	IT Financial Management	COBIT APO06 / EDM02
16.	Audit Trails & Accountability	ISO 27001 A.8.15 / NIST AU
17.	Emerging Technology & Specialized Areas	NIST CSF 2.0 / CSA CCM
—	Risk Rating Methodology	5x5 Matrix Likelihood & Impact
—	Nonconformity Classification	Major / Minor / Observation
—	Audit Reporting Templates	Executive Summary Finding Template
—	IT Audit Maturity Assessment Model	1-5 Scale All 17 Domains
—	Audit Evidence & Working Papers	Evidence Types WP Index
—	Document Review Checklist	6 Categories Pre-Audit Checklist
—	Audit Compliance Summary Sheet	Domain Ratings Sign-Off
—	About the Author	Saheed Akinloye, CMSA

HOW TO USE THIS CHECKLIST

Each item: Reference | Audit Question | Control Objective | Evidence Required | Risk Rating (H/M/L) | Framework. Record findings, evidence, and compliance status (Compliant / Non-Compliant / Partially Compliant / N/A) in working papers.

1 IT Governance & Management Oversight

COBIT EDM01-05 | COBIT
APO01-02 | ISO 27001 Cl.4-5

Evaluate whether IT governance structures ensure IT strategy aligns with business objectives, decisions are made at the right level, and IT performance is measured and reported to leadership.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
ITG-01	Is there a documented IT strategy aligned with the corporate business strategy?	IT investments support business goals	IT Strategic Plan, Board approval records	H	COBIT APO02
ITG-02	Is the IT strategy reviewed and updated at least annually or after major changes?	Strategy remains current and relevant	Review meeting minutes, version history	M	COBIT APO02
ITG-03	Are IT policies, standards, and procedures documented, approved, and communicated?	Consistent, enforceable IT governance	Policy register, approval signatures, distribution records	H	ISO 27001 Cl.5
ITG-04	Are roles and responsibilities for IT governance clearly defined and assigned?	Clear accountability for IT decisions	RACI matrix, job descriptions, org chart	M	COBIT EDM0 1
ITG-05	Is an IT Steering Committee or equivalent governance body in place and active?	IT decisions are governed at appropriate level	ToR document, meeting minutes (last 12 months)	H	COBIT EDM0 1
ITG-06	Are IT KPIs and SLAs defined, tracked, and reported to senior management?	IT performance is visible and managed	KPI dashboards, management reports, SLA performance data	M	COBIT MEA01
ITG-07	Is there a process for IT policy exceptions with appropriate authorization?	Exceptions are controlled and do not create unmanaged risk	Exception request forms, approval records, register	M	ISO 27001 Cl.6
ITG-08	Are IT governance maturity assessments conducted periodically?	Continuous improvement of IT governance	Maturity assessment results, improvement plans	L	COBIT MEA02

2 IT Risk Management & Compliance

ISO 27001 Cl.6 | COBIT APO12
| ISO 31000

Assess whether IT risks are systematically identified, assessed, treated, and monitored, and that compliance with legal, regulatory, and contractual requirements is tracked and maintained.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
IRM-01	Is an IT risk management framework formally documented and approved?	Structured, repeatable risk identification and treatment	Risk management framework document, approval record	H	ISO 27001 Cl.6.1 / COBIT APO12
IRM-02	Is an IT risk register maintained with risks, owners, ratings, and treatment status?	Complete visibility of IT risk landscape	Risk register (current), risk owner assignments	H	COBIT APO12
IRM-03	Are IT risks assessed using a defined methodology (likelihood x impact)?	Consistent, comparable risk rating	Risk assessment methodology, completed assessments	H	ISO 27001 Cl.6.1.2
IRM-04	Are IT risk assessments conducted at least annually and after significant changes?	Risk register remains current	Assessment schedule, dated assessments	M	ISO 27001 Cl.6.1.2
IRM-05	Is compliance with applicable laws and regulations tracked and managed?	Legal and regulatory obligations are met	Compliance register, legal reviews, breach notification procedures	H	ISO 27001 Cl.4.2
IRM-06	Are third-party and outsourcing risks identified and included in the risk register?	Supply chain and vendor risks are managed	Vendor risk assessments, third-party risk register	H	COBIT APO10
IRM-07	Are risk mitigation actions tracked to completion with defined owners and deadlines?	Risks are actively reduced, not just documented	Action tracker, risk treatment plan status reports	M	ISO 27001 Cl.6.1.3
IRM-08	Is there a defined risk appetite statement approved by senior leadership?	Risk tolerance is clearly communicated	Risk appetite statement, board approval minutes	M	COBIT EDM03

3 Information Security Management

ISO/IEC 27001:2022 Annex A |
NIST SP 800-53 | CIS Controls

Review the effectiveness of the ISMS and associated controls including data classification, cryptography, vulnerability management, security awareness, and incident response capabilities.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
ISM-01	Is an ISMS formally established and maintained?	Systematic approach to managing information security	ISMS scope document, Statement of Applicability	H	ISO 27001 Cl.4-10
ISM-02	Is an information security policy approved by management and communicated to all staff?	All staff understand security obligations	Security policy, distribution/acknowledgement records	H	ISO 27001 A.5.1
ISM-03	Is data/asset classification implemented and handling rules enforced?	Sensitive data receives appropriate protection	Classification policy, data inventory, DLP reports	H	ISO 27001 A.5.12
ISM-04	Are cryptographic controls implemented for data at rest and in transit?	Data confidentiality protected by encryption	Encryption policy, technical configs, key management register	H	ISO 27001 A.8.24
ISM-05	Is a vulnerability management program in place with defined patching SLAs?	Known vulnerabilities are remediated timely	Vulnerability scan reports, patch SLA policy, remediation logs	H	NIST SI-2 / ISO 27001 A.8.8
ISM-06	Is mandatory security awareness training provided and completion tracked?	Reduce human-factor risk	Training records, completion %, phishing simulation results	M	ISO 27001 A.6.3
ISM-07	Is there a documented information security incident response plan (IRP)?	Incidents are managed in a controlled manner	IRP document, tabletop exercise records	H	ISO 27001 A.5.24-5.26
ISM-08	Is physical access to areas processing sensitive information controlled?	Unauthorized physical access prevented	Access control logs, CCTV evidence, visitor register	M	ISO 27001 A.7.2
ISM-09	Are penetration tests conducted at least annually by qualified testers?	Identify exploitable vulnerabilities before attackers do	Pen test reports, remediation tracker, retest results	H	NIST CA-8
ISM-10	Is there a process for managing security exceptions with documented approval?	Unmitigated security gaps are controlled	Exception register, approvals, review schedule	M	ISO 27001 Cl.6

4 IT Asset Management

ISO 27001 A.5.9-5.10 | COBIT
BAI09 | ITIL Asset Mgmt

Verify that all IT assets are inventoried, owned, managed through their lifecycle, and disposed securely.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
AST-01	Is a complete and current hardware asset inventory maintained?	All IT assets are accounted for and managed	Asset register, discovery tool reports, reconciliation records	M	ISO 27001 A.5.9 / COBIT BAI09
AST-02	Is a software asset inventory maintained including version and licensing information?	License compliance and software control	Software inventory, license records, SAM tool reports	M	COBIT BAI09
AST-03	Is an asset owner assigned for each critical IT asset?	Clear accountability for asset management	Asset register with owner field, acknowledgement records	M	ISO 27001 A.5.10
AST-04	Is a CMDB maintained and kept current?	Accurate picture of IT infrastructure configuration	CMDB records, reconciliation reports, change-linked updates	M	ITIL Configuration Mgmt
AST-05	Are end-of-life assets identified and decommissioned in a controlled manner?	Prevent risk from unsupported/unpatched systems	EOL asset register, decommission process, disposal records	H	COBIT BAI09
AST-06	Is software licensing compliance monitored and audited regularly?	Avoid legal and financial exposure from unlicensed software	License audit reports, SAM reports, vendor license agreements	M	COBIT BAI09
AST-07	Are asset disposal procedures defined to ensure secure data destruction?	Prevent data leakage from disposed assets	Data destruction policy, certificates of destruction, disposal logs	H	ISO 27001 A.7.14

5 Identity & Access Management (IAM)

ISO 27001 A.5.15-5.18 | NIST
AC / IA | CIS Control 5-6

Assess whether access to systems and data is provisioned, reviewed, and revoked based on least privilege principles, with MFA and PAM controls enforced for privileged and remote access.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
IAM-01	Is a formal user provisioning process in place requiring authorization before access is granted?	Only authorized users receive access	Access request forms, approval workflow records, ITSM tickets	H	ISO 27001 A.5.16 / NIST AC-2
IAM-02	Is user deprovisioning executed within defined timeframes for leavers/movers?	Prevent unauthorized access from former employees	Leaver process logs, HR-IT notification records, access removal evidence	H	ISO 27001 A.5.18
IAM-03	Is role-based access control (RBAC) implemented and roles defined by least privilege?	Access limited to what is needed for role	Role definitions, access matrix, RBAC configuration	H	NIST AC-3 / ISO 27001 A.5.15
IAM-04	Is privileged access managed through a PAM solution with MFA and session recording?	Privileged access is tightly controlled and auditable	PAM solution logs, MFA config, session recordings	H	NIST AC-6 / CIS Control 5
IAM-05	Are user access rights reviewed at least every 6 months by access owners?	Inappropriate access is detected and removed promptly	Access review reports, recertification sign-offs	H	ISO 27001 A.5.18
IAM-06	Is MFA enforced for all remote access, privileged accounts, and critical systems?	Prevent unauthorized access via compromised credentials	MFA policy, authentication logs, coverage reports	H	NIST IA-2 / ISO 27001 A.8.5
IAM-07	Are password complexity, length, and rotation requirements enforced technically?	Strong passwords reduce credential compromise risk	Password policy, AD/IAM config screenshots	M	NIST IA-5
IAM-08	Are shared/generic accounts prohibited or controlled with justified exceptions?	Individual accountability for system actions	Account audit reports, exception register	H	ISO 27001 A.5.16
IAM-09	Are service accounts and non-human identities inventoried and reviewed?	Non-human access is controlled and monitored	Service account register, review records, usage logs	M	NIST AC-2

6 IT Operations & Service Management

ITIL 5 | COBIT DSS01-02 | ISO
20000

Evaluate IT service management practices including incident, problem, and service request management, service desk operations, SLA performance, and operational monitoring.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
OPS-01	Is a service catalog documented with defined scope, SLAs, and ownership?	Clear IT service offering and accountability	Service catalog, SLA agreements, ownership matrix	M	ITIL Service Catalog Mgmt
OPS-02	Is the incident management process documented with classification, escalation, and resolution SLAs?	Incidents are resolved efficiently within agreed timeframes	Incident management procedure, ITSM reports, SLA metrics	H	ITIL Incident Mgmt
OPS-03	Is problem management conducted to identify root causes and prevent recurrence?	Reduce recurring incidents and their business impact	Problem records, RCA reports, Known Error Database (KEDB)	M	ITIL Problem Mgmt
OPS-04	Is service request management handled through a formal request fulfillment process?	Service requests handled consistently and within SLA	Request fulfillment procedure, ITSM queue metrics	L	ITIL Service Request Mgmt
OPS-05	Is the service desk staffed, trained, and operating according to defined procedures?	Effective first-line IT support for users	Service desk procedures, training records, CSAT scores	M	ITIL Service Desk
OPS-06	Are OLAs defined between internal IT teams to support SLA delivery?	Internal dependencies support external SLA commitments	OLA documents, performance reports	M	ITIL SLM
OPS-07	Is an IT event monitoring process in place with defined alert thresholds and escalations?	IT issues are detected before they impact services	Monitoring tool config, alert rules, escalation procedure	H	ITIL Event Mgmt / NIST SI-4
OPS-08	Are operational IT procedures documented for critical processes?	Consistent, repeatable operations	Runbooks, operational procedure documents, job schedules	M	COBIT DSS01

7 Change Management & Release Management

ITIL Change Control | COBIT
BAI06-07 | SOX ITGC

Review the end-to-end change process for authorization, testing, segregation of duties, emergency change handling, patch management, and post-implementation review.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
CHG-01	Is a Change Management policy documented covering standard, normal, and emergency changes?	All changes follow a consistent, controlled process	Change Management policy, change type definitions	H	ITIL Change Control / COBIT BAI06
CHG-02	Are all changes submitted via a formal change request and reviewed by a CAB?	Changes assessed for risk and authorized before implementation	Change requests in ITSM tool, CAB meeting minutes	H	ITIL Change Control
CHG-03	Is an impact and risk assessment mandatory for all changes before CAB approval?	Change risks are identified and mitigated proactively	Completed impact/risk sections on change records	H	ITIL Change Control
CHG-04	Are changes tested in a non-production environment prior to production deployment?	Changes do not introduce defects or outages	Test results, UAT sign-off documents, test environment evidence	H	COBIT BAI07
CHG-05	Is segregation of duties enforced (developers cannot deploy to production)?	Unauthorized or untested code cannot reach production	Access rights matrix, deployment access review, ITSM audit trail	H	COBIT BAI06 / SOX
CHG-06	Are rollback plans required and documented for all significant changes?	Failed changes can be reversed quickly	Rollback plan field in change record, PIR results	M	ITIL Change Control
CHG-07	Is an emergency change process defined with post-implementation review requirement?	Emergency changes are controlled and reviewed	Emergency change procedure, emergency change records and PIRs	H	ITIL Change Control
CHG-08	Are security patches classified and applied within defined SLA timeframes?	Critical vulnerabilities are addressed before exploitation	Patch management policy, scan results, patch application logs	H	NIST SI-2 / CIS Control 7
CHG-09	Are post-implementation reviews (PIRs) conducted after major changes?	Changes are evaluated for effectiveness and lessons learned	PIR records, improvement actions logged	L	ITIL Change Control

8 IT Infrastructure & Network Security

ISO 27001 A.8.20-8.22 | NIST
SC/SI | CIS Controls 12-13

Assess the security posture of the network, servers, endpoints, and cloud infrastructure including segmentation, hardening, backup, and capacity management.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
INF-01	Is the network architecture documented with clear segmentation (DMZ, internal, management zones)?	Limit blast radius of attacks via network segmentation	Network architecture diagram, firewall zone config	H	ISO 27001 A.8.22 / NIST SC-7
INF-02	Are firewall rules reviewed at least annually and unauthorized rules removed?	Only necessary network traffic is permitted	Firewall rule review evidence, dated review reports	H	NIST SC-7 / CIS Control 12
INF-03	Are IDS/IPS systems deployed and alerts monitored in real time?	Detect and block network-based attacks	IDS/IPS configuration, alert monitoring evidence, SOC logs	H	NIST SI-4 / CIS Control 13
INF-04	Is server hardening performed according to a documented baseline (e.g., CIS Benchmarks)?	Reduce attack surface on servers and endpoints	Hardening standards, compliance scan reports	H	CIS Controls / NIST CM-6
INF-05	Are endpoint protection solutions (EDR/AV) deployed and updated on all endpoints?	Malware and endpoint threats are detected and contained	EDR deployment reports, update status, coverage metrics	H	ISO 27001 A.8.7 / CIS Control 10
INF-06	Is cloud infrastructure secured according to shared responsibility model with CSPM in place?	Cloud misconfiguration and exposure prevented	CSPM tool reports, cloud security policy, misconfiguration tracker	H	CSA CCM / NIST
INF-07	Are data backups taken regularly, tested, and stored securely offsite/in separate cloud region?	Data can be recovered after loss or ransomware attack	Backup policy, test restoration records, offsite storage config	H	ISO 27001 A.8.13 / NIST CP-9
INF-08	Is capacity management practiced with utilization thresholds and growth projections?	Performance degradation and outages are prevented proactively	Capacity plan, utilization trend reports, threshold alert config	M	ITIL Capacity Mgmt / COBIT DSS01
INF-09	Are wireless networks secured using enterprise authentication with guest segregation?	Unauthorized wireless access prevented	Wireless config, RADIUS authentication records, guest VLAN config	M	ISO 27001 A.8.20 / NIST AC-18

9 Application Controls & Systems Development

NIST SA | COBIT BAI03 |
OWASP | ISO 27001
A.8.25-8.29

Review SDLC controls, secure coding practices, application security testing, access controls, input validation, interface security, and testing/deployment processes.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
APP-01	Is an SDLC policy documented with security requirements at each phase?	Security is built in, not bolted on	SDLC policy, security gate checklists, phase sign-off records	H	NIST SA-3 / ISO 27001 A.8.25
APP-02	Are secure coding standards adopted and developers trained in secure coding practices?	Reduce software vulnerabilities at source	Secure coding standards, training records, code review guidelines	H	OWASP / NIST SA-8
APP-03	Is SAST/DAST integrated into the development pipeline?	Detect vulnerabilities before production deployment	SAST/DAST tool integration evidence, scan reports	H	NIST SA-11 / ISO 27001 A.8.29
APP-04	Are application access controls enforced at transaction and function level?	Users can only access functions they are authorized for	Application role matrix, access control testing evidence	H	COBIT BAI03 / NIST AC-3
APP-05	Are input validation controls in place to prevent injection attacks (SQL, XSS, etc.)?	Application integrity protected from malicious input	Code review evidence, SAST results, penetration test findings	H	OWASP Top 10 / NIST SI-10
APP-06	Are interfaces and data transfer processes between systems authenticated and encrypted?	Data integrity and confidentiality in transit	Interface documentation, encryption config, API security review	H	ISO 27001 A.8.24 / NIST SC-8
APP-07	Are UAT and SIT formally conducted with sign-off before go-live?	Applications meet business requirements before go-live	UAT/SIT test plans, results, business sign-off records	M	COBIT BAI07
APP-08	Is application output/report data integrity verified to prevent unauthorized modification?	Output data is accurate and trustworthy	Output reconciliation procedures, audit trail logs	M	COBIT BAI03

10 Data Management & Protection

ISO 27001 A.5.12 | GDPR | ISO
27701 | NIST SP 800-53

Evaluate data classification, ownership, retention, disposal, integrity controls, privacy impact assessments, and cross-border transfer compliance.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
DMP-01	Is a data classification policy in place with defined categories and handling requirements?	Data is identified and handled according to sensitivity	Classification policy, data inventory with classification labels	H	ISO 27001 A.5.12
DMP-02	Are data owners assigned for all critical data sets with documented responsibilities?	Clear accountability for data protection	Data ownership register, responsibility documentation	M	ISO 27001 A.5.10
DMP-03	Is a data retention and disposal policy defined and enforced across systems?	Data is kept only as long as required and disposed securely	Retention policy, disposal records, automated purge evidence	H	ISO 27001 A.5.33 / GDPR Art.5
DMP-04	Are backup and restoration processes defined, tested, and aligned with RPO requirements?	Data can be restored to meet business continuity needs	Backup policy, restoration test results, RPO register	H	ISO 27001 A.8.13 / NIST CP-9
DMP-05	Are data integrity controls in place to detect and prevent unauthorized modification?	Data accuracy and completeness is assured	Audit trail logs, checksums, reconciliation reports	H	NIST SI-7 / COBIT DSS06
DMP-06	Are privacy impact assessments (PIA/DPIA) conducted for new systems handling personal data?	Privacy risks identified and mitigated before processing begins	DPIA records, DPO review, project approval gates	H	GDPR Art.35 / ISO 27701
DMP-07	Is personal data transferred cross-border only under appropriate legal mechanisms?	Cross-border data transfers comply with applicable law	Data transfer agreements, SCCs, adequacy decisions	H	GDPR Chapter 5
DMP-08	Are database access controls implemented to restrict who can query, modify, or export data?	Prevent unauthorized access to data at the database layer	Database access controls, DBA account review, query audit logs	H	NIST AC-3 / ISO 27001 A.5.15

11 Logging, Monitoring & Incident Response

ISO 27001 A.8.15-8.16 | NIST
AU/IR | ITIL Incident Mgmt

Assess log collection, SIEM capability, log integrity, retention, 24/7 monitoring, incident detection/escalation, and post-incident review processes.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
LMR-01	Is logging enabled on all critical systems with standardized log format?	Security events can be detected and investigated	Logging policy, SIEM source list, sample log evidence	H	ISO 27001 A.8.15 / NIST AU-2
LMR-02	Are logs centralized in a SIEM solution with correlation rules and alerting?	Security events are detected across the environment	SIEM architecture, detection rule catalog, alert evidence	H	NIST SI-4 / CIS Control 8
LMR-03	Are logs protected from tampering (e.g., write-once storage, separate log server)?	Log integrity maintained for forensic use	Log storage config, access controls, integrity check mechanism	H	ISO 27001 A.8.15 / NIST AU-9
LMR-04	Are log retention periods defined in policy and enforced (minimum 12 months recommended)?	Logs available for investigation and compliance	Retention policy, log archive config, storage reports	H	ISO 27001 A.8.15 / NIST AU-11
LMR-05	Is the SIEM monitored 24/7 with documented escalation procedures?	Security alerts receive timely response	SOC operation model, shift records, escalation playbooks	H	NIST IR-6 / ISO 27001 A.5.25
LMR-06	Is an incident detection, classification, and escalation matrix documented?	Incidents trigger appropriate and timely response	Incident classification matrix, escalation procedure	H	ITIL Incident Mgmt / NIST IR-4
LMR-07	Are post-incident reviews (PIRs) conducted for all P1/P2 incidents?	Learning from incidents to improve detection and response	Post-incident review reports, action trackers	M	ITIL Problem Mgmt / NIST IR-5
LMR-08	Are privileged user activities specifically logged and reviewed?	Detect insider threats and privilege abuse	PAM audit logs, privileged activity review records	H	NIST AU-2 / ISO 27001 A.8.15

12 Business Continuity & Disaster Recovery

ISO 22301 | NIST CP | COBIT
DSS04 | ISO 27001 A.5.30

Review BIA currency, DR plan completeness, RTO/RPO definition, actual recovery test results, offsite backup, and BCP scope and communication.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
BCR-01	Is a Business Impact Analysis (BIA) conducted and regularly updated?	Critical processes and RTO/RPO requirements are identified	BIA document, review schedule, business unit sign-off	H	ISO 22301 / COBIT DSS04
BCR-02	Is a Disaster Recovery Plan (DRP) documented, approved, and tested at least annually?	IT systems can be recovered within RTO targets	DRP document, test exercise reports, management approval	H	ISO 22301 / NIST CP-2
BCR-03	Are RTO and RPO defined for all critical systems?	Recovery expectations are set and validated	RTO/RPO register, BIA-aligned system criticality list	H	ISO 22301 / NIST CP-2
BCR-04	Are actual recovery times validated through DR testing against defined RTOs?	Recovery capability is proven, not assumed	DR test results with measured recovery times vs RTO targets	H	NIST CP-4
BCR-05	Are backups stored offsite or in a geographically separate location?	Backups survive a site-level disaster	Offsite backup agreement, cloud backup configuration	H	ISO 27001 A.8.13 / NIST CP-9
BCR-06	Is a BCP covering people, process, and technology documented?	Business operations can continue during IT outages	BCP document, manual workaround procedures, staff call tree	H	ISO 22301 / COBIT DSS04
BCR-07	Are BCP/DRP plans communicated to relevant staff and available during incidents?	Plans are accessible and known when needed	Communication records, plan access mechanism, staff awareness test	M	ISO 22301

13 Physical & Environmental Security

ISO 27001 A.7 | NIST PE | ISO
27001 A.7.2-7.12

Assess physical access controls, CCTV, fire suppression, power continuity, environmental monitoring, and clean desk policies for data centers and offices.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
PHY-01	Is access to data centers and server rooms controlled via electronic access?	Unauthorized physical access to IT infrastructure prevented	Access control system config, access logs, visitor register	H	ISO 27001 A.7.2 / NIST PE-3
PHY-02	Is CCTV surveillance in place at data center entry/exit with footage retained?	Physical security incidents can be detected and investigated	CCTV configuration, retention settings, sample footage review	H	ISO 27001 A.7.4 / NIST PE-6
PHY-03	Are fire suppression systems installed and tested regularly?	Fire risk to IT assets is mitigated	Fire suppression system certificates, test records, maintenance logs	H	ISO 27001 A.7.5 / NIST PE-13
PHY-04	Is a UPS and generator in place for critical IT infrastructure?	IT systems remain operational during power outages	UPS/generator spec, load test records, maintenance logs	H	ISO 27001 A.7.11 / NIST PE-11
PHY-05	Are environmental controls (temperature, humidity) monitored and alerted on breach?	Equipment operates within safe environmental parameters	Environmental monitoring tool config, alert thresholds, logs	M	ISO 27001 A.7.8 / NIST PE-14
PHY-06	Is physical access to data centers reviewed at least quarterly?	Access rights remain appropriate and current	Access review records, approval records for access	M	ISO 27001 A.7.2
PHY-07	Are clean desk and screen lock policies enforced for sensitive areas?	Sensitive information not exposed when unattended	Policy document, spot-check records, screen lock config	M	ISO 27001 A.7.7

14 Vendor & Third-Party Management

ISO 27001 A.5.19-5.22 | COBIT
APO10 | ITIL Supplier Mgmt

Evaluate vendor due diligence, contractual protections, third-party access controls, ongoing performance monitoring, SOC 2 review, and vendor exit procedures.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
VND-01	Is a vendor risk assessment process in place prior to onboarding?	Vendor risks identified before engagement	Vendor assessment forms, risk tier register, due diligence records	H	ISO 27001 A.5.19 / COBIT APO10
VND-02	Do vendor contracts include data protection, security, right-to-audit, and incident notification clauses?	Contractual obligations protect the organization	Sample vendor contracts, DPA agreements, security annexures	H	ISO 27001 A.5.19-5.20
VND-03	Is third-party access to organizational systems controlled and monitored?	Vendor access does not introduce unmanaged risk	Vendor access policy, access logs, remote access controls	H	ISO 27001 A.5.19 / NIST AC-17
VND-04	Are vendor SLAs monitored and performance reviews conducted at least quarterly?	Vendor performance meets contractual obligations	Vendor scorecards, review meeting minutes, SLA reports	M	ITIL Supplier Mgmt / COBIT APO10
VND-05	Are SOC 2 Type II reports obtained and reviewed for critical vendors annually?	Third-party controls assurance obtained independently	SOC 2 reports, management review evidence, exception tracker	M	AICPA SOC / COBIT APO10
VND-06	Are cloud service providers assessed for data residency, compliance, and security controls?	Cloud providers meet organizational security and legal requirements	CSP security certifications, contract data residency clauses, CSPM reports	H	CSA CCM / ISO 27017
VND-07	Is there a vendor exit/termination procedure ensuring data return or destruction?	Organizational data is protected at contract end	Exit procedure document, data destruction certificates	H	ISO 27001 A.5.20

15 IT Financial Management

COBIT APO06 | COBIT EDM02
| COBIT BAI09

Review IT budgeting, investment planning and prioritization, asset cost tracking, cost optimization practices, and project financial reporting.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
FIN-01	Is an IT budget defined, approved by leadership, and tracked against actual spend?	IT spending is controlled and accountable	IT budget document, variance reports, approval records	M	COBIT APO06
FIN-02	Are IT investment proposals subject to business case review and prioritization?	IT investments deliver value and are aligned with strategy	Investment proposals, business case templates, steering committee minutes	M	COBIT APO06 / EDM02
FIN-03	Are IT assets tracked for depreciation and total cost of ownership?	Accurate financial picture of IT estate	Asset register with financial data, depreciation schedules	L	COBIT BAI09
FIN-04	Are IT cost optimization initiatives actively pursued and reported?	IT costs are managed efficiently	Cost optimization register, cloud cost reports, license rationalization evidence	L	COBIT APO06
FIN-05	Are IT project costs tracked against approved budgets with variance reporting?	IT projects are delivered within financial parameters	Project financial reports, PMO cost tracker	M	COBIT BAI01

16 Audit Trails & Accountability

ISO 27001 A.8.15 | NIST AU |
COBIT DSS06 | SOX

Verify availability and integrity of audit logs, segregation of duties enforcement, non-repudiation controls, and tracking of prior audit findings.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
AUD-01	Are audit logs available for all critical systems covering authentication, transactions, and admin actions?	User actions are traceable for accountability and investigation	Audit log configuration, sample audit trail extracts	H	ISO 27001 A.8.15 / NIST AU-2
AUD-02	Are audit logs reviewed regularly for anomalous activity?	Unauthorized or suspicious activity is detected	Log review schedule, anomaly alert records, reviewer sign-off	H	NIST AU-6 / ISO 27001 A.8.16
AUD-03	Is segregation of duties enforced in critical processes (finance, access provisioning, change management)?	No single individual can perpetrate and conceal fraud or errors	SoD matrix, access rights review, process walkthroughs	H	COBIT DSS06 / SOX
AUD-04	Are non-repudiation controls in place (digital signatures, timestamps)?	Actions are provably attributable to specific users/systems	Digital signature implementation, timestamp config, PKI evidence	M	ISO 27001 A.5.33 / NIST AU-10
AUD-05	Are audit trail access controls in place to prevent tampering by administrators?	Audit logs are reliable and cannot be altered	SIEM access controls, write-once log storage config	H	NIST AU-9 / ISO 27001 A.8.15
AUD-06	Are audit findings from previous audits tracked and corrective actions verified?	Repeat findings are prevented through effective remediation	Finding tracker, management action plans, evidence of closure	M	ISO 19011 / COBIT MEA02

17 Emerging Technology & Specialized Areas

NIST CSF 2.0 | CSA CCM |
NIST AI RMF | ISO 42001

Assess controls for cloud computing, cybersecurity maturity, DevSecOps pipelines, AI/automation risk, remote work security, software supply chain, and API security.

Ref	Checklist Item / Audit Question	Control Objective	Evidence Required	Risk	Framework
EMG-01	Are cloud computing controls aligned with shared responsibility model (AWS/Azure/GCP)?	Security responsibilities are clearly defined and implemented	Cloud policy, shared responsibility matrix, CSP security documentation	H	CSA CCM / ISO 27017
EMG-02	Is cybersecurity maturity assessed against NIST CSF or equivalent and gaps remediated?	Structured approach to improving cyber defenses	NIST CSF assessment, maturity scores, improvement roadmap	H	NIST CSF 2.0
EMG-03	Are DevOps/CI-CD pipelines subject to security controls (SAST, secret scanning, image scanning)?	Automated pipelines do not introduce security vulnerabilities	Pipeline security gates, secret scanning config, SAST integration	H	NIST SA-11 / DevSecOps
EMG-04	Are AI and automation tools assessed for data privacy, bias, and security risks before deployment?	AI/automation tools do not introduce unmanaged risk	AI risk assessment, model governance policy, data handling review	H	NIST AI RMF / ISO 42001
EMG-05	Are remote work endpoints secured (MDM, VPN, encrypted storage, EDR)?	Remote working does not expand attack surface	MDM policy, VPN configuration, device encryption status reports	H	NIST AC-17 / ISO 27001 A.6.7
EMG-06	Is a software supply chain security program in place (SBOMs, open source risk)?	Third-party code does not introduce vulnerabilities	SBOM policy, open source scanning tool reports, vendor code review process	H	NIST SR-3 / EO 14028
EMG-07	Are API security controls in place (authentication, rate limiting, input validation)?	APIs do not expose data or systems to unauthorized access	API security policy, API gateway config, pen test API results	H	OWASP API Security / NIST SC-8
EMG-08	Is there a process for monitoring and responding to emerging threats (threat intelligence)?	Organization is aware of relevant threats and can respond	Threat intelligence subscription, TI-to-alert workflow, IOC integration	M	NIST RA-10 / ISO 27001 A.5.7

RISK RATING METHODOLOGY

Findings are classified using a 5x5 risk matrix combining Likelihood and Impact. Risk Score = Likelihood x Impact. Use this matrix to prioritize audit findings.

Risk Rating Matrix

Use this matrix to classify findings by likelihood and impact.

Likelihood / Impact	Insignificant (1)	Minor (2)	Moderate (3)	Major (4)	Catastrophic (5)
Rare (1)	1 Low	2 Low	3 Low	4 Medium	5 Medium
Unlikely (2)	2 Low	4 Medium	6 Medium	8 High	10 High
Possible (3)	3 Low	6 Medium	9 High	12 High	15 Critical
Likely (4)	4 Medium	8 High	12 High	16 Critical	20 Critical
Almost Certain (5)	5 Medium	10 High	15 Critical	20 Critical	25 Critical

Critical (15-25)

High (8-14)

Medium (4-7)

Low (1-3)

Likelihood Assessment Criteria

Score	Level	Description
1	Rare	The event is not expected to occur; less than once in 10 years.
2	Unlikely	The event could occur but is not expected; once in 3-10 years.
3	Possible	The event might occur occasionally; once in 1-3 years.
4	Likely	The event will probably occur; once or more per year.
5	Almost Certain	The event is expected to occur multiple times per year.

Impact Assessment Criteria

Score	Level	Description
1	Insignificant	Negligible business impact; easily absorbed. No regulatory concern.
2	Minor	Minor disruption; limited financial loss; no regulatory breach.
3	Moderate	Moderate impact on operations; financial loss; possible regulatory attention.
4	Major	Significant disruption; substantial financial loss; regulatory action likely.
5	Catastrophic	Severe disruption; existential financial or reputational damage; regulatory sanctions.

NONCONFORMITY CLASSIFICATION

All audit findings must be classified into one of three categories. Classification drives urgency of corrective action and follow-up requirements.

MAJOR NONCONFORMITY

Definition:	The absence of, or total breakdown of, a system or process required by the applicable standard or policy. Systemic failure preventing the organization from achieving the intent of a requirement.
Examples:	No ISMS in place. No documented DR plan. Production access completely uncontrolled. Zero security awareness training delivered.
Required Action:	Immediate corrective action plan required within 30 days. Evidence of implementation submitted within 60 days. Mandatory follow-up audit within 90 days.
Remediation Timeline:	30–60 days

MINOR NONCONFORMITY

Definition:	A lapse or isolated deviation from a requirement that does not represent a systemic failure and does not pose an immediate critical risk to the organization.
Examples:	One policy not reviewed on scheduled date. A single access review delayed by 4 weeks. Backup restoration test overdue by 6 weeks.
Required Action:	Documented corrective action plan required. Evidence submitted to auditor within agreed timeframe. Closure confirmed in next scheduled audit.
Remediation Timeline:	60–90 days

OBSERVATION / OPPORTUNITY FOR IMPROVEMENT (OFI)

Definition:	A situation that does not currently constitute a nonconformity but could deteriorate into one if not addressed. Includes opportunities for improvement.
Examples:	Vendor management process improving but not fully documented. SLA performance trending toward breach. Security training at 72% completion and improving.
Required Action:	No formal corrective action required. Management should acknowledge, monitor, and consider addressing in next review cycle. Auditor will note in follow-up.
Remediation Timeline:	90–180 days

AUDIT REPORTING TEMPLATES

Standardised templates for documenting and communicating audit outcomes to management and stakeholders.

Executive Summary Template

Audit Title:	[e.g., IT Audit — Q1 2026]
Audit Period:	[Start Date] to [End Date]
Lead Auditor:	[Name, Qualification, e.g., CMSA, CISA, ISO 27001 LA]
Audit Scope:	[Systems, processes, locations, business units covered]
Applicable Standards:	[e.g., ISO/IEC 27001:2022, ISO 22301, ITIL 5]
Overall Opinion:	[Satisfactory / Partially Satisfactory / Unsatisfactory]
Major Nonconformities:	[Count and brief description]
Minor Nonconformities:	[Count and brief description]
Observations / OFIs:	[Count and brief description]
Key Strengths Noted:	[Notable positive control observations]
Priority Recommendations:	[Top 3-5 prioritised recommendations for management action]
Next Steps:	[Follow-up audit target date; management response deadline]

Individual Audit Finding Template

Finding Reference:	[e.g., MaNC-003; MiNC-001; OBS-002]
Audit Domain:	[e.g., Access Control & Identity Management]
Finding Title:	[Concise, descriptive title]
Classification:	[Major NC / Minor NC / Observation]
Risk Rating:	[Critical / High / Medium / Low]
Applicable Standard:	[e.g., ISO 27001:2022 A.5.18]
Control Objective:	[What the control was expected to achieve]
Condition (What Found):	[Factual description of what the auditor observed]
Criteria (What Required):	[The standard, policy, or requirement not met]
Cause (Root Cause):	[Identified root cause of the deviation]
Effect / Risk:	[Potential business/security impact if not remediated]
Evidence Reference:	[Working paper number or attachment reference]
Recommendation:	[Specific, actionable recommendation]
Management Response:	[Auditee's agreed corrective action plan]
Action Owner:	[Name and title of responsible person]
Target Completion Date:	[Date by which corrective action will be complete]
Closure Status:	[Open / In Progress / Closed - Verified]

IT AUDIT MATURITY ASSESSMENT MODEL

Rate each domain on a 1-5 maturity scale. Aggregate scores provide an overall IT governance maturity rating.

Maturity Level Definitions

Level	Characteristics
1 — Initial	Processes are ad hoc, reactive, and largely undocumented. Success depends on individual heroics.
2 — Developing	Basic processes exist but are informal and inconsistently applied. Some documentation present.
3 — Defined	Processes are documented, standardised, and communicated. Applied consistently. Regularly reviewed.
4 — Managed	Processes are measured and controlled using defined KPIs. Quantitative management in place.
5 — Optimising	Continuous improvement through innovation, automation, and benchmarking against best practice.

Maturity Assessment Scorecard — All 17 Domains

Domain	Current Score (1-5)	Target Score	Gap	Key Gap / Improvement Priority
1. IT Governance & Management Oversight				
2. IT Risk Management & Compliance				
3. Information Security Management				
4. IT Asset Management				
5. Identity & Access Management (IAM)				
6. IT Operations & Service Management				
7. Change Management & Release Management				
8. IT Infrastructure & Network Security				
9. Application Controls & Systems Development				
10. Data Management & Protection				
11. Logging, Monitoring & Incident Response				
12. Business Continuity & Disaster Recovery				
13. Physical & Environmental Security				
14. Vendor & Third-Party Management				
15. IT Financial Management				
16. Audit Trails & Accountability				
17. Emerging Technology & Specialized Areas				
OVERALL MATURITY SCORE				Average of all domain scores

AUDIT EVIDENCE & WORKING PAPERS

All audit findings must be supported by sufficient, appropriate evidence documented in working papers.

Types of Audit Evidence

Evidence Type	Description	Examples
Physical	Direct observation of tangible assets, processes, or controls in operation.	Data centre access observation, physical lock inspection, screen lock check.
Documentary	Written or electronic records created by the auditee.	Policies, procedures, logs, reports, contracts, registers, system configurations.
Testimonial	Statements from auditees obtained through interviews or written responses.	Interview notes, questionnaire responses, management representations.
Analytical	Results of comparisons, computations, analysis, or data queries performed by auditor.	Access review analysis, SLA performance calculations, trend analysis, sampling results.
Confirmatory	Evidence obtained from independent third parties.	ISO/SOC 2 certificates, vendor pen test reports, external audit reports.
Re-performance	Auditor independently re-executing a control to verify it operates as described.	Re-running a backup restoration, re-performing an access provisioning workflow.

Working Paper Index

WP Ref	Description of Working Paper	Audit Domain	Prepared By	Date	Reviewed By	Status
WP-001						Open/Closed
WP-002						Open/Closed
WP-003						Open/Closed
WP-004						Open/Closed

DOCUMENT REVIEW CHECKLIST

Request the following documents at the commencement of each IT audit engagement. Record availability, date obtained, currency, and relevant notes.

A. Governance & Strategy

#	Document	Obtained (Y/N)	Date Obtained	Current? (Y/N)	Notes / Observations
1	IT Strategic Plan / IT Roadmap	Y / N	__/__/__	Y / N	
2	IT Governance Charter / Framework	Y / N	__/__/__	Y / N	
3	IT Steering Committee ToR & Meeting Minutes (12 months)	Y / N	__/__/__	Y / N	
4	IT Policies, Standards & Procedures Register	Y / N	__/__/__	Y / N	
5	IT Organisational Chart & Role Descriptions	Y / N	__/__/__	Y / N	
6	IT Budget & Expenditure Variance Reports	Y / N	__/__/__	Y / N	
7	IT KPI / Performance Dashboard Reports	Y / N	__/__/__	Y / N	

B. Information Security

#	Document	Obtained (Y/N)	Date Obtained	Current? (Y/N)	Notes / Observations
1	Information Security Policy & Sub-Policies	Y / N	__/__/__	Y / N	
2	ISMS Scope Document & Statement of Applicability (SoA)	Y / N	__/__/__	Y / N	
3	Information Risk Register & Risk Treatment Plan	Y / N	__/__/__	Y / N	
4	Data Classification Policy & Information Asset Register	Y / N	__/__/__	Y / N	
5	Security Awareness Training Completion Records	Y / N	__/__/__	Y / N	
6	Vulnerability Scan & Penetration Test Reports (12 months)	Y / N	__/__/__	Y / N	
7	Security Incident Log & Post-Incident Reviews	Y / N	__/__/__	Y / N	

C. IT Operations & Service Management

#	Document	Obtained (Y/N)	Date Obtained	Current? (Y/N)	Notes / Observations
1	IT Service Catalog	Y / N	__/__/__	Y / N	
2	SLA Agreements & Performance Reports	Y / N	__/__/__	Y / N	
3	Incident & Problem Management Reports	Y / N	__/__/__	Y / N	
4	Change Advisory Board (CAB) Minutes (12 months)	Y / N	__/__/__	Y / N	
5	Change Request Register & Emergency Change Records	Y / N	__/__/__	Y / N	
6	Backup Policy & Restoration Test Results	Y / N	__/__/__	Y / N	
7	Capacity & Performance Management Reports	Y / N	__/__/__	Y / N	

D. Access Control & Identity Management

#	Document	Obtained (Y/N)	Date Obtained	Current? (Y/N)	Notes / Observations
1	Access Control Policy & Role/RBAC Definitions	Y / N	__/__/__	Y / N	
2	User Provisioning & Deprovisioning Procedure	Y / N	__/__/__	Y / N	

3	Privileged Access Management (PAM) Logs & Review Records	Y / N	__/__/__	Y / N	
4	Periodic Access Review Reports & Sign-Offs	Y / N	__/__/__	Y / N	
5	Leaver/Mover Process Records (sample)	Y / N	__/__/__	Y / N	
6	MFA Configuration & Coverage Reports	Y / N	__/__/__	Y / N	

E. Business Continuity & DR

#	Document	Obtained (Y/N)	Date Obtained	Current? (Y/N)	Notes / Observations
1	Business Continuity Plan (BCP)	Y / N	__/__/__	Y / N	
2	Disaster Recovery Plan (DRP)	Y / N	__/__/__	Y / N	
3	Business Impact Analysis (BIA)	Y / N	__/__/__	Y / N	
4	RTO / RPO Register	Y / N	__/__/__	Y / N	
5	BCP / DR Test Exercise Reports & Post-Test Action Plans	Y / N	__/__/__	Y / N	
6	Offsite Backup Configuration & Storage Agreements	Y / N	__/__/__	Y / N	

F. Compliance, Vendor & Third Party

#	Document	Obtained (Y/N)	Date Obtained	Current? (Y/N)	Notes / Observations
1	Compliance Register & Legal / Regulatory Obligation Log	Y / N	__/__/__	Y / N	
2	Vendor Contract Register	Y / N	__/__/__	Y / N	
3	Data Processing Agreements (DPAs)	Y / N	__/__/__	Y / N	
4	Vendor SOC 2 / ISO 27001 Certificates	Y / N	__/__/__	Y / N	
5	Third-Party Risk Assessment Records	Y / N	__/__/__	Y / N	
6	Cloud Service Provider Security Documentation	Y / N	__/__/__	Y / N	

AUDIT COMPLIANCE SUMMARY SHEET

Record the overall compliance status for each domain after completing the detailed checklist. Provide an aggregate rating, list key findings, and assign responsible owners for remediation.

Domain	Items Reviewed	Compliant	Partial	Non-Compliant	N/A	Overall Rating	Priority Finding
1. IT Governance						S/PS/U	
2. Risk & Compliance						S/PS/U	
3. Info Security						S/PS/U	
4. Asset Management						S/PS/U	
5. IAM						S/PS/U	
6. IT Operations						S/PS/U	
7. Change Management						S/PS/U	
8. Infrastructure						S/PS/U	
9. App Controls						S/PS/U	
10. Data Protection						S/PS/U	
11. Logging & SIEM						S/PS/U	
12. BCDR						S/PS/U	
13. Physical Security						S/PS/U	
14. Vendor Management						S/PS/U	
15. IT Finance						S/PS/U	
16. Audit Trails						S/PS/U	
17. Emerging Tech						S/PS/U	
TOTALS							

S — Satisfactory

PS — Partially Satisfactory

U — Unsatisfactory

AUDIT PROGRAMME SIGN-OFF

Audit Entity:	_____	Audit Period:	_____to _____
Lead Auditor:	_____	Audit Type:	Internal / External / Certification
Review / QA:	_____	Report Date:	_____ _____
Overall Opinion:	Satisfactory / Partially Satisfactory / Unsatisfactory	Follow-up Due:	_____ _____

ABOUT THE AUTHOR

Saheed Akinloye, CMSA

Senior IT Auditor | Compliance Consultant | Governance, Risk & Assurance Specialist

Saheed Akinloye is a highly accomplished and versatile audit and compliance professional with extensive hands-on experience conducting internal, supplier/customer, and certification audits across a broad spectrum of internationally recognised management system standards. His audit competence spans ISO/IEC 27001, ISO 22301, ISO/IEC 20000-1, ISO 9001, and several other ISO and sector-specific frameworks — delivering rigorous, evidence-based assessments that add genuine assurance value to organisations.

With a distinguished track record of auditing across multiple industries, Saheed has delivered audit and advisory engagements for organisations in Financial Services, FinTech, Information Technology, Telecommunications, Manufacturing, and the Public Sector. This cross-sector breadth enables him to apply context-aware, risk-based audit thinking that is both technically grounded and commercially relevant — ensuring organisations derive maximum value from every engagement.

Saheed brings exceptional depth in IT governance, information security assurance, IT service management, and regulatory compliance. He is proficient in COBIT 2019, ITIL 5, NIST Cybersecurity Framework, and ISO 19011 audit principles — translating complex control frameworks into clear, actionable recommendations that resonate with both technical teams and executive leadership.

As a trusted advisor, Saheed is actively available to provide audit, advisory, and consulting services — including IT audit programme design, ISMS gap assessments, ISO certification readiness, control framework implementation, business continuity planning, and compliance programme management — helping organisations of all sizes build resilient, compliant, and well-governed IT environments.

Areas of Expertise

● 1st, 2nd & 3rd Party Audits	● ISO/IEC 27001:2022	● ISO 22301	● ISO/IEC 20000-1	● ISO 9001
● IT Governance & COBIT 2019	● ITIL 5 Service Management	● NIST CSF & SP 800-53	● Risk-Based Auditing	● GRC Frameworks
● Banking & FinTech Audits	● IT & Telecoms Audits	● Manufacturing Audits	● Compliance Advisory	● Audit Programme Design

Sectors Audited

Banking & Financial Services	FinTech	Information Technology
Telecommunications	Manufacturing	Public Sector

Get In Touch — Audit, Advisory & Consulting Services

Saheed is available for IT audit engagements, compliance advisory, ISO management system implementation and certification readiness, GRC framework design, and risk-based audit programme development across all sectors.

Email: saheed.akinloye@toolboxqhse.com

Phone / WhatsApp: +234 812 228 1817

Framework references: ISO/IEC 27001:2022, ITIL 5, COBIT 2019, NIST SP 800-53 Rev.5, ISO 22301, ISO 20000-1, ISO 19011:2018, GDPR, OWASP.
Framework references are intellectual properties of their respective owners (ISO, PeopleCert, ISACA, NIST).

This checklist is provided for professional audit guidance only.

IT AUDIT CHECKLIST | For IT Auditors | Saheed Akinloye, CMSA